

NIST SP 800-53 Rev 5 control AU-10.1 (Association of Identities) summarizes the requirements for this control: AU-10.1 · Association of Identities Control Statement: (a) Bind the identity of the information producer with the information to [organization-defined parameter] ; and (b) Provide the means for authorized individuals to determine the identity of the producer of the information. Supplemental Guidance: (a) Bind the identity of the information producer with the information to [organization-defined parameter] ; and (b) Provide the means for authorized individuals to determine the identity of the p

Under the FedRAMP High baseline, AU-7 (AU-7 Audit Record Reduction and Report Generation): FedRAMP High Baseline · AU-7 · Audit Record Reduction and Report Generation Control Statement: Provide and implement an audit record reduction and report generation capability that: a. Supports on-demand audit record review, analysis, and reporting requirements and after-the-fact investigations of incidents; and b. Does not alter the original content or time ordering of audit records. Supplemental Guidance: Provide and implement an audit record reduction and report generation capability that:

Under the FedRAMP High baseline, AU-6.6 (AU-6.6 Correlation with Physical Monitoring): FedRAMP High Baseline · AU-6.6 · Correlation with Physical Monitoring Control Statement: Correlate information from audit records with information obtained from monitoring physical access to further enhance the ability to identify suspicious, inappropriate, unusual, or malevolent activity. Supplemental Guidance: Correlate information from audit records with information obtained from monitoring physical access to further enhance the ability to identify suspicious, inappropriate, unusual, or mal

NIST SP 800-53 Rev 5 control AU-10.1 (Association of Identities) is assessed by examining, interviewing, and testing: AU-10.1 · Association of Identities Control Statement: (a) Bind the identity of the information producer with the information to [organization-defined parameter] ; and (b) Provide the means for authorized individuals to determine the identity of the producer of the information. Supplemental Guidance: (a) Bind the identity of the information producer with the information to [organization-defined parameter] ; and (b) Provide the means for authorized individuals to determine the identity of the p

NIST SP 800-171 Rev 3 control 03.03.04 (03.03.04 Response to Audit Logging Process Failures) falls under the Audit and Accountability family. Control Statement: SR-03.03.04.a Alert organizational personnel or roles within [organization-defined parameter] in the event of an audit logging process failure. SR-03.03.04.b Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: Audit logging process failures include software and hardware errors, failures in audit log capturing mechanisms, and reaching or exceeding audit log storage capacity. Response actions include overwriting the oldest audit records, shutting down the system, and stopping the generation of audit records. Organizations may choose to define additional actions for audit logging process failures based on the type of failure, the location of the failure, the severity of the failure

AU-3 · Content of Audit Records Control Statement: Ensure that audit records contain information that establishes the following: a. What type of event occurred; b. When the event occurred; c. Where the event occurred; d. Source of the event; e. Outcome of the event; and f. Identity of any individuals, subjects, or objects/entities associated with the event. Supplemental Guidance: Ensure that audit records contain information that establishes the following: a. What type of event occurred; b. When the event occurred; c. Where the event occurred; d. Source of the event; e. Outcome of the event; and f. Identity of any individuals, subjects, or objects/entities associated with the event. Audit record content that may be necessary to support the auditing function includes event descriptions (item a), time stamps (item b), source and destination addresses (item c), user or process identifiers (items d and f), success or fail indications (item e), and filenames involved (items a, c, e, and f) . Event outcomes include indicators of event success or failure and event-specific results, such as the system security and privacy posture after the event occurred. Organizations consider how audit records can reveal information about individuals that may give rise to privacy risks and how best to mitigate such risks. For example, there is the potential to reveal personally identifiable information in the audit trail, especially if the trail records inputs or is based on patterns or time of usage.

NIST SP 800-171 Rev 3 control 03.03.03 (03.03.03 Audit Record Generation) falls under the Audit and Accountability family. Control Statement: SR-03.03.03.a Generate audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02. SR-03.03.03.b Retain audit records for a time period consistent with the records retention policy. Supplemental Guidance: Audit records can be generated at various levels of abstraction, including at the packet level as information traverses the network. Selecting the appropriate level of abstraction is a critical aspect of an audit logging capability and can facilitate the identification of root causes to problems. The ability to add information generated in audit records is dependent on system functionality to configure the audit record content. Organizations may consider additional informa

NIST SP 800-53 Rev 5 control AU-6.7 (Permitted Actions) is assessed by examining, interviewing, and testing: AU-6.7 · Permitted Actions Control Statement: Specify the permitted actions for each [organization-defined parameter] associated with the review, analysis, and reporting of audit record information. Supplemental Guidance: Specify the permitted actions for each [organization-defined parameter] associated with the review, analysis, and reporting of audit record information. Organizations specify permitted actions for system processes, roles, and users associated with the review, analysis, and re

NIST SP 800-53 Rev 5 control AU-12.1 (System-wide and Time-correlated Audit Trail) is assessed by examining, interviewing, and testing: AU-12.1 · System-wide and Time-correlated Audit Trail Control Statement: Compile audit records from [organization-defined parameter] into a system-wide (logical or physical) audit trail that is time-correlated to within [organization-defined parameter]. Supplemental Guidance: Compile audit records from [organization-defined parameter] into a system-wide (logical or physical) audit trail that is time-correlated to within [organization-defined parameter]. Audit trails are time-correlated if the

NIST SP 800-53 Rev 5 control AU-5 (Response to Audit Logging Process Failures): AU-5 · Response to Audit Logging Process Failures Control Statement: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event

NIST SP 800-171 Rev 3 control 03.03.07 (03.03.07 Time Stamps) falls under the Audit and Accountability family. Control Statement: SR-03.03.07.a Use internal system clocks to generate time stamps for audit records. SR-03.03.07.b Record time stamps for audit records that meet [organization-defined parameter] and that use Coordinated Universal Time (UTC), have a fixed local time offset from UTC, or include the local time offset as part of the time stamp. Supplemental Guidance: Time stamps generated by the system include the date and time. Time is often expressed in Coordinated Universal Time (UTC) · a modern continuation of Greenwich Mean Time (GMT) · or local time with an offset from UTC. The granularity of time measurements refers to the degree of synchronization between system clocks and reference clocks (e.g., clocks synchronizing within hundreds or tens of milliseconds). Organizations may define different time granularities for system compo

Control AU-4: f individuals arising from information processing. Finally, new controls are developed based on new or changing requirements in laws, executive orders, regulations, policies, standards, or guidelines. Proposed modifications to the controls are carefully analyzed during each revision cycle, considering the need for stability of controls and the need to be responsive to changing technologies, threats, vulnerabilities, types of attack, and processing methods. The objective is to adjust the level of information security and privacy over time to meet the needs of organizations and individuals. This publication is available free of charge from : <https://doi.org/10.6028/NIST.SP.800-53r51>. CHAPTER THREE PAGE 17 This publication is available free of charge from : <https://doi.org/10.6028/NIST.SP.800-53r51>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

3.1 ACCESS CONTROL Quick link to Access Control Summary Table

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: AU-08 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.03.07.b [Assignment: organization-defined

granularity of time measurement] a granularity of one (1) second or smaller Configuration Management 3.4.1 Baseline Configuration a. Develop and maintain under configuration control, a current baseline configuration of the system. b. Review and update the baseline configuration of the system [Assignment: organization-defined frequency] (03.04.01.b) and when system components are installed or modified. Related Controls: CM-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.01.b [Assignment: organization-defined frequency] at least every 12 months and after any significant incidents or significant changes occur

NIST SP 800-53 Rev 5 control AU-10.4 (Validate Binding of Information Reviewer Identity) summarizes the requirements for this control: AU-10.4 · Validate Binding of Information Reviewer Identity Control Statement: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to release or transfer between [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Supplemental Guidance: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to

NIST SP 800-171 Rev 3 control 03.03.03 (03.03.03 Audit Record Generation) is assessed by examining the following: Assessment Objectives: - audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02 are generated. - audit records are retained for a time period consistent with the records retention policy.

AU-16.3 · Disassociability Control Statement: Implement [organization-defined parameter] to disassociate individuals from audit information transmitted across organizational boundaries. Supplemental Guidance: Implement [organization-defined parameter] to disassociate individuals from audit information transmitted across organizational boundaries. Preserving identities in audit trails could have privacy ramifications, such as enabling the tracking and profiling of individuals, but may not be operationally necessary. These risks could be further amplified when transmitting information across organizational boundaries. Implementing privacy-enhancing cryptographic techniques can disassociate individuals from audit information and reduce privacy risk while maintaining accountability.

NIST SP 800-53 Rev 5 control AU-5.2 (Real-time Alerts) is assessed by examining, interviewing, and testing: AU-5.2 · Real-time Alerts Control Statement: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Supplemental Guidance: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Alerts provide organizations with urgent messages. Real-time alerts provide these

NIST SP 800-53 Rev 5 control AU-5.2 (Real-time Alerts): AU-5.2 · Real-time Alerts Control Statement: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Supplemental Guidance: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-de

NIST SP 800-171 Rev 3 control 03.03.02 (03.03.02 Audit Record Content) requires organizations to implement the following: Control Statement: SR-03.03.02.a Include the following content in audit records: SR-03.03.02.a.01 What type of event occurred SR-03.03.02.a.02 When the event occurred SR-03.03.02.a.03 Where the event occurred SR-03.03.02.a.04 Source of the event SR-03.03.02.a.05 Outcome of the event SR-03.03.02.a.06 Identity of the individuals, subjects, objects, or entities associated with the event SR-03.03.02.b Provide additional information for audit records as needed. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.02.

Under the FedRAMP Moderate baseline, AU-6.3 (AU-6.3 Correlate Audit Record Repositories): FedRAMP Moderate Baseline · AU-6.3 · Correlate Audit Record Repositories Control Statement: Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Supplemental Guidance: Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Organization-wide situational awareness includes

awareness across all three levels of risk management (i.e., organizational level, mission/business process)

NIST SP 800-53 Rev 5 control AU-4.1 (Transfer to Alternate Storage): AU-4.1 · Transfer to Alternate Storage Control Statement: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component conducting the logging. Supplemental Guidance: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component con

and b. Authorize, monitor, and control the use of mobile code within the system. CHAPTER THREE PAGE 311 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Discussion: Mobile code includes any program, application, or content that can be transmitted across a network (e.g., embedded in an email, document, or website) and executed on a remote system. Decisions regarding the use of mobile code within organizational systems are based on the potential for the code to cause damage to the systems if used maliciously. Mobile code technologies include Java applets, JavaScript, HTML5, WebGL, and VBScript. Usage restrictions and implementation guidelines apply to both the selection and use of mobile code installed on servers and mobile code downloaded and executed on individual workstations and devices, including notebook computers and smart phones. Mobile code policy and procedures address specific actions taken to prevent the development, acquisition, and introduction of unacceptable mobile code within organizational systems, including requiring mobile code to be digitally signed by a trusted source. Related Controls: AU-2, AU-12, CM-2, CM-6, SI-3. Control Enhancements: (1) MOBILE CODE | IDENTIFY UNACCEPTABLE CODE AND TAKE CORRECTIVE ACTIONS Identify [Assignment: organization-defined unacceptable mobile code] and take [Assignment: organization-defined corrective actions].

NIST SP 800-53 Rev 5 control AU-5.3 (Configurable Traffic Volume Thresholds) summarizes the requirements for this control: AU-5.3 · Configurable Traffic Volume Thresholds Control Statement: Enforce configurable network communications traffic volume thresholds reflecting limits on audit log storage capacity and [organization-defined parameter] network traffic above those thresholds. Supplemental Guidance: Enforce configurable network communications traffic volume thresholds reflecting limits on audit log storage capacity and [organization-defined parameter] network traffic above those thresholds. Organizations have

Under the FedRAMP High baseline, AU-6.5 (AU-6.5 Integrated Analysis of Audit Records): FedRAMP High Baseline · AU-6.5 · Integrated Analysis of Audit Records Control Statement: Integrate analysis of audit records with analysis of [organization-defined parameter] to further enhance the ability to identify inappropriate or unusual activity. Supplemental Guidance: Integrate analysis of audit records with analysis of [organization-defined parameter] to further enhance the ability to identify inappropriate or unusual activity. Integrated analysis of audit records does not require vuln

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Audit and Accountability 3.3.5 Audit Record Review and Analysis a. Review and analyze system audit records [Assignment: organization-defined frequency] (03.03.05.a) for indications and the potential impact of inappropriate or unusual activity. b. Report findings to organizational personnel or roles. c. Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Related Controls: AU-06, AU-06(03) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.03.05.a [Assignment: organization-defined frequency] at least weekly Audit and Accountability 3.3.7 Time Stamps for Audit Records a. Use internal system clocks to generate time stamps for audit records. b. Record time stamps for audit records that meet [Assignment: organiz

Implementing 03.03.05 (03.03.05 Audit Record Review, Analysis, and Reporting) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.03.05 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles

infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.03.05 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Implementing 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.03.06 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.03.06 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AU-5.1 (Storage Capacity Warning) summarizes the requirements for this control: AU-5.1 · Storage Capacity Warning Control Statement: Provide a warning to [organization-defined parameter] within [organization-defined parameter] when allocated audit log storage volume reaches [organization-defined parameter] of repository maximum audit log storage capacity. Supplemental Guidance: Provide a warning to [organization-defined parameter] within [organization-defined parameter] when allocated audit log storage volume reaches [organization-defined parameter] of repository maximum

NIST SP 800-171 Rev 3 control 03.03.01 (03.03.01 Event Logging) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.03.05 (03.03.05 Audit Record Review, Analysis, and Reporting) is assessed by examining the following: Assessment Objectives: - system audit records are reviewed and analyzed [organization-defined parameter] for indications and the potential impact of inappropriate or unusual activity. - findings are reported to organizational personnel or roles. - audit records across different repositories are analyzed to gain organization-wide situational awareness. - audit records across different repositories are correlated to gain organization-wide situational awareness.

NIST SP 800-53 Rev 5 control AU-3.3 (Limit Personally Identifiable Information Elements) is assessed by examining, interviewing, and testing: AU-3.3 · Limit Personally Identifiable Information Elements Control Statement: Limit personally identifiable information contained in audit records to the following elements identified in the privacy risk assessment: [organization-defined parameter]. Supplemental Guidance: Limit personally identifiable information contained in audit records to the following elements identified in the privacy risk assessment: [organization-defined parameter]. Limiting personally identifiable information in audit

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Audit and Accountability 3.3.1 Event Logging a. Specify the following event types selected for logging within the system: [Assignment: organization-defined event types] (03.03.01.a). b. Review and update the event types selected for logging [Assignment: organization-defined frequency] (03.03.01.b). Related Controls: AU-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.03.01.a [Assignment: organization-defined event types] at a minimum and where applicable: 1) Authentication events: a) Logons (Success/Failure) b) Logoffs (Success) 2) Security Relevant File and Objects events: a) Create (Success/Failure) b) Access (Success/Failure) c) Delete (Success/Failure) d) Modify (Success/Failure) e) Permission Modification (Success/Failure) f) Ownership Modification

NIST SP 800-53 Rev 5 control AU-7.1 (Automatic Processing) is assessed by examining, interviewing, and testing: AU-7.1 · Automatic Processing Control Statement: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Events of interest can be identified by the content of audit records, including system r

Control AU-16: / N S T S P . 8 0 0 - 5 3 r 5 . I CHAPTER THREE PAGE 82 T h s i p u b l i c a t i o n
i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5> . I NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR
INFORMATION SYSTEMS AND ORGANIZATIONS

3.4 ASSESSMENT, AUTHORIZATION, AND MONITORING Quick link to Assessment, Authorization, and Monitoring Summary Table

NIST SP 800-53 Rev 5 control AU-4.1 (Transfer to Alternate Storage) is assessed by examining, interviewing, and testing: AU-4.1 · Transfer to Alternate Storage Control Statement: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component conducting the logging. Supplemental Guidance: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component conducting the logging. Audit log transfer, also known as off-loading, is a common process in systems w

NIST SP 800-53 Rev 5 control AU-14.3 (Remote Viewing and Listening) summarizes the requirements for this control: AU-14.3 · Remote Viewing and Listening Control Statement: Provide and implement the capability for authorized users to remotely view and hear content related to an established user session in real time. Supplemental Guidance: Provide and implement the capability for authorized users to remotely view and hear content related to an established user session in real time. None.

NIST SP 800-53 Rev 5 control AU-12 (Audit Record Generation) is assessed by examining, interviewing, and testing: AU-12 · Audit Record Generation Control Statement: a. Provide audit record generation capability for the event types the system is capable of auditing as defined in [AU-2a](#au-2_smt.a) on [organization-defined parameter]; b. Allow [organization-defined parameter] to select the event types that are to be logged by specific components of the system; and c. Generate audit records for the event types defined in [AU-2c](#au-2_smt.c) that include the audit record content defined in [AU-3](#au-3). S

NIST SP 800-171 Rev 3 control 03.03.03 (03.03.03 Audit Record Generation) is assessed by examining the following: Assessment Objectives: - audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02 are generated. - audit records are retained for a time period consistent with the records retention policy.

NIST SP 800-53 Rev 5 control AU-13.2 (Review of Monitored Sites) is assessed by examining, interviewing, and testing: AU-13.2 · Review of Monitored Sites Control Statement: Review the list of open-source information sites being monitored [organization-defined parameter]. Supplemental Guidance: Review the list of open-source information sites being monitored [organization-defined parameter]. Reviewing the current list of open-source information sites being monitored on a regular basis helps to ensure that the selected sites remain relevant. The review also provides the opportunity to add new open-source inform

Under the FedRAMP Moderate baseline, AU-2 (AU-2 Event Logging): FedRAMP Moderate Baseline · AU-2 · Event Logging Control Statement: a. Identify the types of events that the system is capable of logging in support of the audit function: [organization-defined parameter]; b. Coordinate the event logging function with other organizational entities requiring audit-related information to guide and inform the selection criteria for events to be logged; c. Specify the following event types for logging within the system: [organization-defined parameter]; d. Provide

NIST SP 800-171 Rev 3 control 03.03.07 (03.03.07 Time Stamps) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide

provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AU-11 (Audit Record Retention) is defined as follows: AU-11 · Audit Record Retention Control Statement: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Supplemental Guidance: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Organizations retain audit records until it is determined that the records are no longer needed for administrative, legal

NIST SP 800-171 Rev 3 control 03.03.05 (03.03.05 Audit Record Review, Analysis, and Reporting) requires organizations to implement the following: Control Statement: SR-03.03.05.a Review and analyze system audit records [organization-defined parameter] for indications and the potential impact of inappropriate or unusual activity. SR-03.03.05.b Report findings to organizational personnel or roles. SR-03.03.05.c Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.05.

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AU-6.4 (Central Review and Analysis) is assessed by examining, interviewing, and testing: AU-6.4 · Central Review and Analysis Control Statement: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Supplemental Guidance: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Automated mechanisms for centralized reviews and analyses include Security Information and Event Management products.

NIST SP 800-53 Rev 5 control AU-6.4 (Central Review and Analysis) summarizes the requirements for this control: AU-6.4 · Central Review and Analysis Control Statement: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Supplemental Guidance: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Automated mechanisms for centralized reviews and analyses include Security Information and Event Management products.

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) requires organizations to implement the following: Control Statement: SR-03.03.06.a Implement an audit record reduction and report generation capability that supports audit record review, analysis, reporting requirements, and after-the-fact investigations of incidents. SR-03.03.06.b Preserve the original content and time ordering of audit records. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.06.

Under the FedRAMP Moderate baseline, AU-3.1 (AU-3.1 Additional Audit Information): FedRAMP Moderate Baseline · AU-3.1 · Additional Audit Information Control Statement: Generate audit records containing the following additional information: [organization-defined parameter]. Supplemental Guidance: Generate audit records containing the following additional information: [organization-defined parameter]. The ability to add information generated in audit records is dependent on system functionality to configure the audit record content. Organizations may consider additional inform

NIST SP 800-53 Rev 5 control AU-7 (Audit Record Reduction and Report Generation) summarizes the requirements for this control: AU-7 · Audit Record Reduction and Report Generation Control Statement: Provide and implement an audit record reduction and report generation capability that: a. Supports on-demand audit record review, analysis, and reporting requirements and after-the-fact

investigations of incidents; and b. Does not alter the original content or time ordering of audit records. Supplemental Guidance: Provide and implement an audit record reduction and report generation capability that: a. Supports on-demand au

NIST SP 800-53 Rev 5 control AU-5.5 (Alternate Audit Logging Capability) is defined as follows: AU-5.5 · Alternate Audit Logging Capability Control Statement: Provide an alternate audit logging capability in the event of a failure in primary audit logging capability that implements [organization-defined parameter]. Supplemental Guidance: Provide an alternate audit logging capability in the event of a failure in primary audit logging capability that implements [organization-defined parameter]. Since an alternate audit logging capability may be a short-term protection solution employed until the failure in the primary audit logging capability is corrected, organizations may determine tha

NIST SP 800-171 Rev 3 control 03.03.02 (03.03.02 Audit Record Content) falls under the Audit and Accountability family. Control Statement: SR-03.03.02.a Include the following content in audit records: SR-03.03.02.a.01 What type of event occurred SR-03.03.02.a.02 When the event occurred SR-03.03.02.a.03 Where the event occurred SR-03.03.02.a.04 Source of the event SR-03.03.02.a.05 Outcome of the event SR-03.03.02.a.06 Identity of the individuals, subjects, objects, or entities associated with the event SR-03.03.02.b Provide additional information for audit records as needed. Supplemental Guidance: Audit record content that may be necessary to support the auditing function includes time stamps, source and destination addresses, user or process identifiers, event descriptions, file names, and the access control or flow control rules that are invoked. Event outcomes can include indicators of event success or failure and event-specific results (e.g., the security state of the system after the event occurred). Detailed information that organizations consider in audit rec

AU-9.3 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Supplemental Guidance: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Cryptographic mechanisms used for protecting the integrity of audit information include signed hash functions using asymmetric cryptography. This enables the distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

Under the FedRAMP High baseline, AU-12.3 (AU-12.3 Changes by Authorized Individuals): FedRAMP High Baseline · AU-12.3 · Changes by Authorized Individuals Control Statement: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined parameter] within [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on

NIST SP 800-53 Rev 5 control AU-3 (Content of Audit Records) is defined as follows: AU-3 · Content of Audit Records Control Statement: Ensure that audit records contain information that establishes the following: a. What type of event occurred; b. When the event occurred; c. Where the event occurred; d. Source of the event; e. Outcome of the event; and f. Identity of any individuals, subjects, or objects/entities associated with the event. Supplemental Guidance: Ensure that audit records contain information that establishes the following: a. What type of event occurred; b. When the event occurred; c. Where the event occurred; d. Source of the event; e. Outcome of the event;

AU-13.2 · Review of Monitored Sites Control Statement: Review the list of open-source information sites being monitored [organization-defined parameter]. Supplemental Guidance: Review the list of open-source information sites being monitored [organization-defined parameter]. Reviewing the current list of open-source information sites being monitored on a regular basis helps to ensure that the selected sites remain relevant. The review also provides the opportunity to add new open-source information sites with the potential to provide evidence of unauthorized disclosure of organizational information. The list of sites monitored can be guided and informed by threat intelligence of other credible sources of information.

NIST SP 800-53 Rev 5 control AU-6.3 (Correlate Audit Record Repositories) summarizes the requirements for this control: AU-6.3 · Correlate Audit Record Repositories Control Statement:

Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Supplemental Guidance: Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Organization-wide situational awareness includes awareness across all three levels of risk management (i.e., organizational level, mission/business process level, and information sy

Under the FedRAMP Moderate baseline, AU-9 (AU-9 Protection of Audit Information): FedRAMP Moderate Baseline · AU-9 · Protection of Audit Information Control Statement: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauthorized access, modification, or deletion of audit information. Supplemental Guidance: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined paramet

NIST SP 800-53 Rev 5 control AU-6.9 (Correlation with Information from Nontechnical Sources) is defined as follows: AU-6.9 · Correlation with Information from Nontechnical Sources Control Statement: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Supplemental Guidance: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Nontechnical sources include records that document organizational policy violations related to harassment incidents and the improper use of information assets. Such information can lead to a directed analytical effort to detect pote

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) is assessed by examining the following: Assessment Objectives: - an audit record reduction and report generation capability that supports audit record review is implemented. - an audit record reduction and report generation capability that supports audit record analysis is implemented. - an audit record reduction and report generation capability that supports audit record reporting requirements is implemented. - an audit record reduction and report generation capability that supports after-the-fact investigations of incidents is implemented. - the original content of audit records is preserved. - the original time ordering of audit

NIST SP 800-53 Rev 5 control AU-9 (Protection of Audit Information) is assessed by examining, interviewing, and testing: AU-9 · Protection of Audit Information Control Statement: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauthorized access, modification, or deletion of audit information. Supplemental Guidance: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauth

NIST SP 800-53 Rev 5 control AU-11 (Audit Record Retention): AU-11 · Audit Record Retention Control Statement: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Supplemental Guidance: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents

FedRAMP Moderate Baseline · AU-5 · Response to Audit Logging Process Failures Control Statement: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. Audit logging process failures include software and hardware errors, failures in audit log capturing mechanisms, and reaching or exceeding audit log storage capacity. Organization-defined actions include overwriting oldest audit records, shutting down the system, and stopping the generation of audit records. Organizations may choose to define additional actions for audit logging process failures based on the type of failure, the location of the failure, the severity of the failure, or a combination of such factors. When the audit logging process failure is related to storage, the response is carried out for the audit log storage repository (i.e., the distinct system component where the audit logs are stored), the system on which the audit logs reside, the total audit log storage capacity of the organization (i.e., all audit log storage repositories combined), or all three. Organizations may decide to take no

additional actions after alerting designated roles or personnel. Assessment Objectives: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. FedRAMP Parameter Values: au-05_odp.01: personnel or roles receiving audit logging process failure alerts are defined; au-05_odp.02: time period for personnel or roles receiving audit logging process failure alerts is defined; au-05_odp.03: overwrite oldest record

NIST SP 800-53 Rev 5 control AU-16.2 (Sharing of Audit Information) is assessed by examining, interviewing, and testing: AU-16.2 · Sharing of Audit Information Control Statement: Provide cross-organizational audit information to [organization-defined parameter] based on [organization-defined parameter]. Supplemental Guidance: Provide cross-organizational audit information to [organization-defined parameter] based on [organization-defined parameter]. Due to the distributed nature of the audit information, cross-organization sharing of audit information may be essential for effective analysis of the auditing being

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) is assessed by examining the following: Assessment Objectives: - access to management of audit logging functionality is authorized to only a subset of privileged users or roles. - audit information is protected from unauthorized access, modification, and deletion. - audit logging tools are protected from unauthorized access, modification, and deletion.

NIST SP 800-53 Rev 5 control AU-4.1 (Transfer to Alternate Storage) summarizes the requirements for this control: AU-4.1 · Transfer to Alternate Storage Control Statement: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component conducting the logging. Supplemental Guidance: Transfer audit logs [organization-defined parameter] to a different system, system component, or media other than the system or system component conducting the logging. Audit log transfer, also known as off-loading, is a common process in systems w

NIST SP 800-53 Rev 5 control AU-16.2 (Sharing of Audit Information) is defined as follows: AU-16.2 · Sharing of Audit Information Control Statement: Provide cross-organizational audit information to [organization-defined parameter] based on [organization-defined parameter]. Supplemental Guidance: Provide cross-organizational audit information to [organization-defined parameter] based on [organization-defined parameter]. Due to the distributed nature of the audit information, cross-organization sharing of audit information may be essential for effective analysis of the auditing being performed. For example, the audit records of one organization may not provide sufficient informatio

NIST SP 800-53 Rev 5 control AU-6.1 (Automated Process Integration) summarizes the requirements for this control: AU-6.1 · Automated Process Integration Control Statement: Integrate audit record review, analysis, and reporting processes using [organization-defined parameter]. Supplemental Guidance: Integrate audit record review, analysis, and reporting processes using [organization-defined parameter]. Organizational processes that benefit from integrated audit record review, analysis, and reporting include incident response, continuous monitoring, contingency planning, investigation and response to suspic

NIST SP 800-171 Rev 3 control 03.03.03 (03.03.03 Audit Record Generation) requires organizations to implement the following: Control Statement: SR-03.03.03.a Generate audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02. SR-03.03.03.b Retain audit records for a time period consistent with the records retention policy. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.03.

NIST SP 800-53 Rev 5 control AU-5 (Response to Audit Logging Process Failures) is assessed by examining, interviewing, and testing: AU-5 · Response to Audit Logging Process Failures Control Statement: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-de

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: ODP Identifier ODP Assignment Text ODP Value 10) System reboot, restart, and shutdown (Success/Failure) 11) Print to a device (Success/Failure) 12) Print to a file (e.g., pdf format) (Success/Failure) 13) Application (e.g., Adobe, Firefox, MS Office Suite) initialization (Success/Failure) For additional guidance, see: OMB21-31 ML 1 03.03.01.b [Assignment: organization-defined frequency] at least every 12 months and after any significant incidents or significant changes to risks Audit and Accountability 3.3.4 Audit Logging Process Failure a. Alert organizational personnel or roles within [Assignment: organization-defined time period] (03.03.04.a) in the event of an audit logging process failure. b. Take the following additional actions: [Assignment: organization-defined

and b. Develop, integrate, and use session auditing activities in consultation with legal counsel and in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Discussion: Session audits can include monitoring keystrokes, tracking websites visited, and recording information and/or file transfers. Session audit capability is implemented in addition to event logging and may involve implementation of specialized session capture technology. Organizations consider how session auditing can reveal information about individuals that may give rise to privacy risk as well as how to mitigate those risks. Because session auditing can impact system and network performance, organizations activate the capability under well-defined situations (e.g., the organization is suspicious of a specific individual). Organizations consult with legal counsel, civil liberties officials, and privacy officials to ensure that any legal, privacy, civil rights, or civil liberties issues, including the use of personally identifiable information, are appropriately addressed. Related Controls: AC-3, AC-8, AU-2, AU-3, AU-4, AU-5, AU-8, AU-9, AU-11, AU-12. Control Enhancements: (1) SESSION AUDIT | SYSTEM START-UP Initiate session audits automatically at system start-up. Discussion: The automatic initiation of session audits at startup helps to ensure that the information being captured on selected individuals is complete and not subject to compromise through tampering by malicious threat actors. Related Controls: None.

NIST SP 800-53 Rev 5 control AU-12.3 (Changes by Authorized Individuals) summarizes the requirements for this control: AU-12.3 · Changes by Authorized Individuals Control Statement: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined parameter] within [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined pa

NIST SP 800-53 Rev 5 control AU-16 (Cross-organizational Audit Logging) summarizes the requirements for this control: AU-16 · Cross-organizational Audit Logging Control Statement: Employ [organization-defined parameter] for coordinating [organization-defined parameter] among external organizations when audit information is transmitted across organizational boundaries. Supplemental Guidance: Employ [organization-defined parameter] for coordinating [organization-defined parameter] among external organizations when audit information is transmitted across organizational boundaries. When organizations use systems

NIST SP 800-53 Rev 5 control AU-13.1 (Use of Automated Tools) summarizes the requirements for this control: AU-13.1 · Use of Automated Tools Control Statement: Monitor open-source information and information sites using [organization-defined parameter]. Supplemental Guidance: Monitor open-source information and information sites using [organization-defined parameter]. Automated mechanisms include commercial services that provide notifications and alerts to organizations and automated scripts to monitor new posts on websites.

NIST SP 800-53 Rev 5 control AU-4 (Audit Log Storage Capacity) is assessed by examining, interviewing, and testing: AU-4 · Audit Log Storage Capacity Control Statement: Allocate audit log storage capacity to accommodate [organization-defined parameter]. Supplemental Guidance: Allocate audit log storage capacity to accommodate [organization-defined parameter]. Organizations consider the types of audit logging to be performed and the audit log processing requirements when allocating audit log storage capacity. Allocating sufficient audit log storage capacity reduces the likelihood of such capacity being excee

Implementing 03.03.02 (03.03.02 Audit Record Content) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.03.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.03.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.03.07 (03.03.07 Time Stamps) is assessed by examining the following: Assessment Objectives: - internal system clocks are used to generate time stamps for audit records. - time stamps are recorded for audit records that use Coordinated Universal Time (UTC), have a fixed local time offset from UTC, or include the local time offset as part of the time stamp. - time stamps are recorded for audit records that meet [organization-defined parameter].

NIST SP 800-53 Rev 5 control AU-13.3 (Unauthorized Replication of Information) is defined as follows: AU-13.3 · Unauthorized Replication of Information Control Statement: Employ discovery techniques, processes, and tools to determine if external entities are replicating organizational information in an unauthorized manner. Supplemental Guidance: Employ discovery techniques, processes, and tools to determine if external entities are replicating organizational information in an unauthorized manner. The unauthorized use or replication of organizational information by external entities can cause adverse impacts on organizational operations and assets, including damage to reputation. Such activities

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 REQUIREMENT NUMBER ENHANCED
SECURITY REQUIREMENT REQUIREMENT TYPE 03.02.04E Anti-Counterfeit Training T SP 800-53, SR-11(01)
Audit and Accountability 03.03.01E Protection of Audit Record Storage in Separate Physical Systems
or Components E 03.03.08 03.03.02E Real-Time Alerts for Audit Processing Failures E 03.03.04
03.03.03E Dual Authorization for Audit Information and Actions E 03.03.08 03.03.04E Integrated
Analysis of Audit Records E 03.03.05 Configuration Management 03.04.01E Withdrawn 03.04.02E
Automated Unauthorized Component Detection E 03.04.10 03.04.03E Automation Maintenance of System
Component Inventory E 03.04.10 03.04.04E Automation Support for Baseline

NIST SP 800-53 Rev 5 control AU-7 (Audit Record Reduction and Report Generation) is assessed by examining, interviewing, and testing: AU-7 · Audit Record Reduction and Report Generation Control Statement: Provide and implement an audit record reduction and report generation capability that: a. Supports on-demand audit record review, analysis, and reporting requirements and after-the-fact investigations of incidents; and b. Does not alter the original content or time ordering of audit records. Supplemental Guidance: Provide and implement an audit record reduction and report generation capability that: a. Supports on-demand au

NIST SP 800-53 Rev 5 control AU-11 (Audit Record Retention) is assessed by examining, interviewing, and testing: AU-11 · Audit Record Retention Control Statement: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Supplemental Guidance: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Organizations retain

NIST SP 800-53 Rev 5 control AU-12 (Audit Record Generation) summarizes the requirements for this control: AU-12 · Audit Record Generation Control Statement: a. Provide audit record generation capability for the event types the system is capable of auditing as defined in [AU-2a](#au-2_smt.a) on [organization-defined parameter]; b. Allow [organization-defined parameter] to select the event types that are to be logged by specific components of the system; and c. Generate audit records for the event types defined in [AU-2c](#au-2_smt.c) that include the audit record content defined in

[AU-3](#au-3). S

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) falls under the Audit and Accountability family. Control Statement: SR-03.03.08.a Protect audit information and audit logging tools from unauthorized access, modification, and deletion. SR-03.03.08.b Authorize access to management of audit logging functionality to only a subset of privileged users or roles. Supplemental Guidance: Audit information includes the information needed to successfully audit system activity, such as audit records, audit log settings, audit reports, and personally identifiable information. Audit logging tools are programs and devices used to conduct audit and logging activities. The protection of audit information focuses on technical protection and limits the ability to access and execute audit logging tools to authorized individuals. The physical protection of audit infor

Under the FedRAMP High baseline, AU-5.2 (AU-5.2 Real-time Alerts): FedRAMP High Baseline · AU-5.2 · Real-time Alerts Control Statement: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Supplemental Guidance: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Alerts provide organizations with urgent messages. Real-ti

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control AU-16.1 (Identity Preservation) is defined as follows: AU-16.1 · Identity Preservation Control Statement: Preserve the identity of individuals in cross-organizational audit trails. Supplemental Guidance: Preserve the identity of individuals in cross-organizational audit trails. Identity preservation is applied when there is a need to be able to trace actions that are performed across organizational boundaries to a specific individual.

NIST SP 800-53 Rev 5 control AU-6 (Audit Record Review, Analysis, and Reporting) is assessed by examining, interviewing, and testing: AU-6 · Audit Record Review, Analysis, and Reporting Control Statement: a. Review and analyze system audit records [organization-defined parameter] for indications of [organization-defined parameter] and the potential impact of the inappropriate or unusual activity; b. Report findings to [organization-defined parameter] ; and c. Adjust the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence info

NIST SP 800-53 Rev 5 control AU-9.1 (Hardware Write-once Media) is assessed by examining, interviewing, and testing: AU-9.1 · Hardware Write-once Media Control Statement: Write audit trails to hardware-enforced, write-once media. Supplemental Guidance: Write audit trails to hardware-enforced, write-once media. Writing audit trails to hardware-enforced, write-once media applies to the initial generation of audit trails (i.e., the collection of audit records that represents the information to be used for detection, analysis, and reporting purposes) and to the backup of those audit trails. Writing audit trails

Under the FedRAMP High baseline, AU-6.3 (AU-6.3 Correlate Audit Record Repositories): FedRAMP High Baseline · AU-6.3 · Correlate Audit Record Repositories Control Statement: Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Supplemental Guidance: Analyze and correlate audit records across different repositories to gain organization-wide situational awareness. Organization-wide situational awareness includes awareness across all three levels of risk management (i.e., organizational level, mission/business process l

NIST SP 800-53 Rev 5 control AU-13.1 (Use of Automated Tools) is assessed by examining, interviewing, and testing: AU-13.1 · Use of Automated Tools Control Statement: Monitor open-source information and information sites using [organization-defined parameter]. Supplemental Guidance: Monitor open-source information and information sites using [organization-defined parameter]. Automated mechanisms include commercial services that provide notifications and alerts to

organizations and automated scripts to monitor new posts on websites.

NIST SP 800-53 Rev 5 control AU-12.2 (Standardized Formats): AU-12.2 · Standardized Formats
Control Statement: Produce a system-wide (logical or physical) audit trail composed of audit records in a standardized format. Supplemental Guidance: Produce a system-wide (logical or physical) audit trail composed of audit records in a standardized format. Audit records that follow common standards promote interoperability and information exchange between devices

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 862 P reclude (Preempt), Impede (Exert) REFERENCES Source Control: AU-05(02) 03.03.03 E Dual Authorization for Audit Information and Actions Enforce dual authorization for [Selection (one or more): movement; deletion] of [Assignment: organization-defined audit information]. DISCUSSION Dual authorization is also known as two-person control since it requires the approval of two authorized individuals to reduce the risk related to insider threat when executing audit functions. Dual authorization reduces risks related to insider threats, including adversaries who have obtained credentials. Organizations may choose different selection options for different types of audit information. To reduce the risk of collusion, organizations consider rotating dual authorizati

NIST SP 800-53 Rev 5 control AU-13 (Monitoring for Information Disclosure): AU-13 · Monitoring for Information Disclosure Control Statement: a. Monitor [organization-defined parameter] [organization-defined parameter] for evidence of unauthorized disclosure of organizational information; and b. If an information disclosure is discovered: 1. Notify [organization-defined parameter] ; and 2. Take the following additional actions: [organization-defined parameter]. Suppl

NIST SP 800-171 Rev 3 control 03.03.04 (03.03.04 Response to Audit Logging Process Failures) requires organizations to implement the following: Control Statement: SR-03.03.04.a Alert organizational personnel or roles within [organization-defined parameter] in the event of an audit logging process failure. SR-03.03.04.b Take the following additional actions: [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.04.

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) falls under the Audit and Accountability family. Control Statement: SR-03.03.06.a Implement an audit record reduction and report generation capability that supports audit record review, analysis, reporting requirements, and after-the-fact investigations of incidents. SR-03.03.06.b Preserve the original content and time ordering of audit records. Supplemental Guidance: Audit records are generated in [](#/cprt/framework/version/SP_800_171_3_0_0/home?element=03.03.03)03.03.03. Audit record reduction and report generation occur after audit record generation. Audit record reduction is a process that manipulates collected audit information and organizes it in a summary format that is more meaningful to analysts. Audit record reduction and report generation capabilities do not always come from the same system or organizational entities that co

Under the FedRAMP High baseline, AU-6.4 (AU-6.4 Central Review and Analysis): FedRAMP High Baseline · AU-6.4 · Central Review and Analysis Control Statement: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Supplemental Guidance: Provide and implement the capability to centrally review and analyze audit records from multiple components within the system. Automated mechanisms for centralized reviews and analyses include Security Information and Event Management products. Assessment Objectives:

NIST SP 800-53 Rev 5 control AU-1 (Policy and Procedures) summarizes the requirements for this control: AU-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] audit and accountability policy that: 2. Procedures to facilitate the implementation of the audit and accountability policy and the associated audit and accountability controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the audit and accountability policy and proced

Control AU-2: d on attributes. Related Controls: None. (8) ACCOUNT MANAGEMENT | DYNAMIC ACCOUNT MANAGEMENT Create, activate, manage, and deactivate [Assignment: organization-defined system

accounts] dynamically. Discussion: Approaches for dynamically creating, activating, managing, and deactivating system accounts rely on automatically provisioning the accounts at runtime for entities that were previously unknown. Organizations plan for the dynamic management, creation, activation, and deactivation of system accounts by establishing trust relationships, business rules, and mechanisms with appropriate authorities to validate related authorizations and privileges. Related Controls: AC-16. (9) ACCOUNT MANAGEMENT | RESTRICTIONS ON USE OF SHARED AND GROUP ACCOUNTS Only permit the use of shared and group accounts that meet [Assignment: organization-defined conditions for establishing shared and group accounts]. Discussion: Before permitting the use of shared or group accounts, organizations consider the increased risk due to the lack of accountability with such accounts. Related Controls: None. (10) ACCOUNT MANAGEMENT | SHARED AND GROUP ACCOUNT CREDENTIAL CHANGE [Withdrawn: Incorporated into AC-2k.] (11) ACCOUNT MANAGEMENT | USAGE CONDITIONS Enforce [Assignment: organization-defined circumstances and/or usage conditions] for [Assignment: organization-defined system accounts]. Discussion: Specifying and enforcing usage conditions helps to enforce the principle of least privilege, increase user accountability, and enable effective account monitoring. Account monitoring includes alerts generated if the account is used in violation of organizational parameters. Organizations can describe specific conditions or circumstances under which system accounts can be used, such as by restricting usage to certain days of the week, time of day, or specific durations of time. Related Controls: None.

Under the FedRAMP High baseline, AU-7.1 (AU-7.1 Automatic Processing): FedRAMP High Baseline · AU-7.1 · Automatic Processing Control Statement: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Events of interest can be identified by the content of audit rec

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) requires organizations to implement the following: Control Statement: SR-03.03.08.a Protect audit information and audit logging tools from unauthorized access, modification, and deletion. SR-03.03.08.b Authorize access to management of audit logging functionality to only a subset of privileged users or roles. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.08.

NIST SP 800-171 Rev 3 control 03.03.02 (03.03.02 Audit Record Content) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.03.02 (03.03.02 Audit Record Content) requires organizations to implement the following: Control Statement: SR-03.03.02.a Include the following content in audit records: SR-03.03.02.a.01 What type of event occurred SR-03.03.02.a.02 When the event occurred SR-03.03.02.a.03 Where the event occurred SR-03.03.02.a.04 Source of the event SR-03.03.02.a.05 Outcome of the event SR-03.03.02.a.06 Identity of the individuals, subjects, objects, or entities associated with the event SR-03.03.02.b Provide additional information for audit records as needed. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.02.

Under the FedRAMP High baseline, AU-5.1 (AU-5.1 Storage Capacity Warning): FedRAMP High Baseline · AU-5.1 · Storage Capacity Warning Control Statement: Provide a warning to [organization-defined parameter] within [organization-defined parameter] when allocated audit log storage volume reaches [organization-defined parameter] of repository maximum audit log storage capacity. Supplemental Guidance: Provide a warning to [organization-defined parameter] within [organization-defined parameter] when allocated audit log storage volume reaches [organization-defined parameter]

NIST SP 800-171 Rev 3 control 03.03.01 (03.03.01 Event Logging) requires organizations to implement the following: Control Statement: SR-03.03.01.a Specify the following event types selected for logging within the system: [organization-defined parameter]. SR-03.03.01.b Review and update the

event types selected for logging [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.01.

NIST SP 800-53 Rev 5 control AU-5.3 (Configurable Traffic Volume Thresholds): AU-5.3 · Configurable Traffic Volume Thresholds Control Statement: Enforce configurable network communications traffic volume thresholds reflecting limits on audit log storage capacity and [organization-defined parameter] network traffic above those thresholds. Supplemental Guidance: Enforce configurable network communications traffic volume thresholds reflecting limits on audit log storage capacity

NIST SP 800-171 Rev 3 control 03.03.05 (03.03.05 Audit Record Review, Analysis, and Reporting) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.03.07 (03.03.07 Time Stamps) is assessed by examining the following: Assessment Objectives: - internal system clocks are used to generate time stamps for audit records. - time stamps are recorded for audit records that use Coordinated Universal Time (UTC), have a fixed local time offset from UTC, or include the local time offset as part of the time stamp. - time stamps are recorded for audit records that meet [organization-defined parameter].

AU-9.4 · Access by Subset of Privileged Users Control Statement: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Supplemental Guidance: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Individuals or roles with privileged access to a system and who are also the subject of an audit by that system may affect the reliability of the audit information by inhibiting audit activities or modifying audit records. Requiring privileged access to be further defined between audit-related privileges and other privileges limits the number of users or roles with audit-related privileges.

NIST SP 800-53 Rev 5 control AU-9.2 (Store on Separate Physical Systems or Components) summarizes the requirements for this control: AU-9.2 · Store on Separate Physical Systems or Components Control Statement: Store audit records [organization-defined parameter] in a repository that is part of a physically different system or system component than the system or component being audited. Supplemental Guidance: Store audit records [organization-defined parameter] in a repository that is part of a physically different system or system component than the system or component being audited. Storing audit records in a repository se

NIST SP 800-53 Rev 5 control AU-6.9 (Correlation with Information from Nontechnical Sources) is assessed by examining, interviewing, and testing: AU-6.9 · Correlation with Information from Nontechnical Sources Control Statement: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Supplemental Guidance: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Nontechnical sources include records that document organizational policy violations related to harassment incidents and the improper

NIST SP 800-53 Rev 5 control AU-13 (Monitoring for Information Disclosure) is assessed by examining, interviewing, and testing: AU-13 · Monitoring for Information Disclosure Control Statement: a. Monitor [organization-defined parameter] [organization-defined parameter] for evidence of unauthorized disclosure of organizational information; and b. If an information disclosure is discovered: 1. Notify [organization-defined parameter] ; and 2. Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: a. Monitor [organization-defined parameter] [organization-defined parameter] for e

NIST SP 800-53 Rev 5 control AU-6.5 (Integrated Analysis of Audit Records) summarizes the requirements for this control: AU-6.5 · Integrated Analysis of Audit Records Control Statement: Integrate analysis of audit records with analysis of [organization-defined parameter] to further enhance the ability to identify inappropriate or unusual activity. Supplemental Guidance: Integrate analysis of audit records with analysis of [organization-defined parameter] to further enhance the

ability to identify inappropriate or unusual activity. Integrated analysis of audit records does not require vulnerability scanning, the

NIST SP 800-171 Rev 3 control 03.03.04 (03.03.04 Response to Audit Logging Process Failures) is assessed by examining the following: Assessment Objectives: - organizational personnel or roles are alerted in the event of an audit logging process failure within [organization-defined parameter]. - the following additional actions are taken: [organization-defined parameter].

NIST SP 800-53 Rev 5 control AU-10.4 (Validate Binding of Information Reviewer Identity) is assessed by examining, interviewing, and testing: AU-10.4 · Validate Binding of Information Reviewer Identity Control Statement: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to release or transfer between [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Supplemental Guidance: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to

NIST SP 800-53 Rev 5 control AU-9 (Protection of Audit Information) summarizes the requirements for this control: AU-9 · Protection of Audit Information Control Statement: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauthorized access, modification, or deletion of audit information. Supplemental Guidance: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauth

NIST SP 800-53 Rev 5 control AU-16.1 (Identity Preservation) summarizes the requirements for this control: AU-16.1 · Identity Preservation Control Statement: Preserve the identity of individuals in cross-organizational audit trails. Supplemental Guidance: Preserve the identity of individuals in cross-organizational audit trails. Identity preservation is applied when there is a need to be able to trace actions that are performed across organizational boundaries to a specific individual.

Implementing 03.03.01 (03.03.01 Event Logging) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.03.01 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.03.01 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AU-12.3 (Changes by Authorized Individuals) is defined as follows: AU-12.3 · Changes by Authorized Individuals Control Statement: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined parameter] within [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined parameter] within [organization-defined parameter]. Permitting authorized individuals to make changes

NIST SP 800-171 Rev 3 control 03.03.01 (03.03.01 Event Logging) is assessed by examining the following: Assessment Objectives: - the following event types are specified for logging within the system: [organization-defined parameter]. - the event types selected for logging are reviewed [organization-defined parameter]. - the event types selected for logging are updated [organization-defined parameter].

NIST SP 800-53 Rev 5 control AU-9.2 (Store on Separate Physical Systems or Components): AU-9.2 · Store on Separate Physical Systems or Components Control Statement: Store audit records

[organization-defined parameter] in a repository that is part of a physically different system or system component than the system or component being audited. Supplemental Guidance: Store audit records [organization-defined parameter] in a repository that is part of a physically different system or s

NIST SP 800-171 Rev 3 control 03.03.01 (03.03.01 Event Logging) is assessed by examining the following: Assessment Objectives: - the following event types are specified for logging within the system: [organization-defined parameter]. - the event types selected for logging are reviewed [organization-defined parameter]. - the event types selected for logging are updated [organization-defined parameter].

, is responsible for the protection of this information. All contracts which grant access to NNPI must require compliance with the specific safeguarding requirements contained in OPNAVINST N9210.3. All waivers or deviations involving security requirements protecting NNPI require Naval Reactors' concurrence. Classified NNPI may not be processed on any contractor information system unless approved by the cognizant authorizing authority with concurrence from Naval Reactors. § 117.24 Cognizant Security Office information. (a) DoD. Refer to the DCSA website (<https://www.dcsa.mil>) for a listing of office locations and areas of responsibility and for information on verification of facility clearances and safeguarding. In those cases where the cleared facility is located on a DoD installation the applicable DCSA field office can advise if the installation commander is providing security oversight. Table 1 to Paragraph (a) DoD Cognizant Security Office

Designation	Office name	Mailing address	Telephone No.
Headquarters, CSO	Defense Counterintelligence and Security Agency	27130 Telegraph Rd., Quantico, VA 22134	(888) 282-7682

(b) DOE. Table 2 to Paragraph (b) DOE Cognizant Security Offices

Designation	Office name	Mailing address	Telephone No.
Headquarters	Headquarters Office of Security Operations (AU-40)	19901 Germantown Road, Germantown, MD 20874	(301) 903-2177
CSO, Clearance Agency, Central Verification Activity, Adjudicative Authority, and PCL and FCL databases	DOE/National Nuclear Security Administration Office of Personnel and Facility Clearances and Classifications	Pennsylvania & H Street, Kirtland Air Force Base, Albuquerque, NM 87116	(505) 845-4154
CSO U.S. Department of Energy, Idaho Operations Office	850 Energy Drive, Idaho Falls, ID 83401	(208) 526-2216	

Table 3 to Paragraph (b) DOE Cognizant Security Offices Continued

Designation	Office name	Mailing address	Telephone No.
CSO, Naval Nuclear Propulsion Information	Director, Naval Reactors	NA-30, 1240 Isaac Hull Ave., SE., Washington Navy Yard, DC 20376	(202) 781-6297
CSO U.S. Department of Energy, Office of Science Consolidated Service Center	200 Administration Road, P.O. Box 2001, Oak Ridge, TN 37830	(865) 576-2140	
CSO U.S. Department of Energy, Pacific Northwest Site Office	902 Battelle Boulevard, Richland, WA 99354	(888) 375-7665	
CSO U.S. Department of Energy, Richland Operations Office	825 Jadwin Avenue, P.O. Box 550, Richland, WA 99352	(509) 376-7411	
CSO U.S. Department of Energy, Savannah River Operations Office	Road 1A, Aiken, SC 29801	(803) 725-6211	

(c) NRC. Table 4 to Paragraph (c) NRC Cognizant Security Offices

Designation	Office name	Mailing address	Telephone No.
CSO, Adjudicative Authority, PCL and FCL databases, and Industrial Security Program	U.S. Nuclear Regulatory Commission, ATTN: Director of Facilities and Security, Washington, DC 20555	(301) 415-8080	
CSO, FCL Database and Industrial Security Program for Licensees	U.S. Nuclear Regulatory Commission, ATTN: Information Security Branch, 11555 Rockville Pike, Rockville, MD 20853	(301) 415-7048	

NIST SP 800-53 Rev 5 control AU-5.2 (Real-time Alerts) summarizes the requirements for this control: AU-5.2 · Real-time Alerts Control Statement: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Supplemental Guidance: Provide an alert within [organization-defined parameter] to [organization-defined parameter] when the following audit failure events occur: [organization-defined parameter]. Alerts provide organizations with urgent messages. Real-time alerts provide these

Under the FedRAMP High baseline, AU-9.4 (AU-9.4 Access by Subset of Privileged Users): FedRAMP High Baseline · AU-9.4 · Access by Subset of Privileged Users Control Statement: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Supplemental Guidance: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Individuals or roles with privileged access to a system and who are also the subject of an audit by that system may affect the reliability of the audit information by inhibiting

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) is assessed by examining the following: Assessment Objectives: - access to management of audit logging functionality is authorized to only a subset of privileged users or roles. - audit information is protected from unauthorized access, modification, and deletion. - audit logging tools are protected from unauthorized access, modification, and deletion.

Under the FedRAMP Moderate baseline, AU-12 (AU-12 Audit Record Generation): FedRAMP Moderate Baseline · AU-12 · Audit Record Generation Control Statement: a. Provide audit record generation capability for the event types the system is capable of auditing as defined in [AU-2a](#au-2_smt.a) on [organization-defined parameter]; b. Allow [organization-defined parameter] to select the event types that are to be logged by specific components of the system; and c. Generate audit records for the event types defined in [AU-2c](#au-2_smt.c) that include the audit record content

Under the FedRAMP High baseline, AU-8 (AU-8 Time Stamps): FedRAMP High Baseline · AU-8 · Time Stamps Control Statement: a. Use internal system clocks to generate time stamps for audit records; and b. Record time stamps for audit records that meet [organization-defined parameter] and that use Coordinated Universal Time, have a fixed local time offset from Coordinated Universal Time, or that include the local time offset as part of the time stamp. Supplemental Guidance: a. Use internal system clocks to generate time stamps for audit records; and b. Rec

NIST SP 800-53 Rev 5 control AU-14.3 (Remote Viewing and Listening) is defined as follows: AU-14.3 · Remote Viewing and Listening Control Statement: Provide and implement the capability for authorized users to remotely view and hear content related to an established user session in real time. Supplemental Guidance: Provide and implement the capability for authorized users to remotely view and hear content related to an established user session in real time. None.

NIST SP 800-53 Rev 5 control AU-2 (Event Logging) is assessed by examining, interviewing, and testing: AU-2 · Event Logging Control Statement: a. Identify the types of events that the system is capable of logging in support of the audit function: [organization-defined parameter]; b. Coordinate the event logging function with other organizational entities requiring audit-related information to guide and inform the selection criteria for events to be logged; c. Specify the following event types for logging within the system: [organization-defined parameter]; d. Provide a rationale for why the even

Under the FedRAMP High baseline, AU-3 (AU-3 Content of Audit Records): FedRAMP High Baseline · AU-3 · Content of Audit Records Control Statement: Ensure that audit records contain information that establishes the following: a. What type of event occurred; b. When the event occurred; c. Where the event occurred; d. Source of the event; e. Outcome of the event; and f. Identity of any individuals, subjects, or objects/entities associated with the event. Supplemental Guidance: Ensure that audit records contain information that establishes the following: a. What type

Under the FedRAMP High baseline, AU-9.3 (AU-9.3 Cryptographic Protection): FedRAMP High Baseline · AU-9.3 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Supplemental Guidance: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Cryptographic mechanisms used for protecting the integrity of audit information include signed hash functions using asymmetric cryptography. This enables the distribution of the public key to verify the

NIST SP 800-53 Rev 5 control AU-3.1 (Additional Audit Information) summarizes the requirements for this control: AU-3.1 · Additional Audit Information Control Statement: Generate audit records containing the following additional information: [organization-defined parameter]. Supplemental Guidance: Generate audit records containing the following additional information: [organization-defined parameter]. The ability to add information generated in audit records is dependent on system functionality to configure the audit record content. Organizations may consider additional information in audit records inclu

NIST SP 800-171 Rev 3 control 03.03.04 (03.03.04 Response to Audit Logging Process Failures) is assessed by examining the following: Assessment Objectives: - organizational personnel or roles are alerted in the event of an audit logging process failure within [organization-defined parameter]. - the following additional actions are taken: [organization-defined parameter].

NIST SP 800-53 Rev 5 control AU-10.3 (Chain of Custody) is defined as follows: AU-10.3 · Chain of Custody Control Statement: Maintain reviewer or releaser credentials within the established chain of custody for information reviewed or released. Supplemental Guidance: Maintain reviewer or releaser credentials within the established chain of custody for information reviewed or released. Chain of custody is a process that tracks the movement of evidence through its collection, safeguarding, and analysis life cycle by documenting each individual who handled the evidence, the date and time the evidence was collected or transferred, and the purpose for the transfer. If the r

NIST SP 800-53 Rev 5 control AU-11.1 (Long-term Retrieval Capability) summarizes the requirements for this control: AU-11.1 · Long-term Retrieval Capability Control Statement: Employ [organization-defined parameter] to ensure that long-term audit records generated by the system can be retrieved. Supplemental Guidance: Employ [organization-defined parameter] to ensure that long-term audit records generated by the system can be retrieved. Organizations need to access and read audit records requiring long-term storage (on the order of years). Measures employed to help facilitate the retrieval of audit records

NIST SP 800-53 Rev 5 control AU-9.3 (Cryptographic Protection) summarizes the requirements for this control: AU-9.3 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Supplemental Guidance: Implement cryptographic mechanisms to protect the integrity of audit information and audit tools. Cryptographic mechanisms used for protecting the integrity of audit information include signed hash functions using asymmetric cryptography. This enables the distribution of the public key to verify the hash information while

Implementing 03.03.03 (03.03.03 Audit Record Generation) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.03.03 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.03.03 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control AU-11 (Audit Record Retention) summarizes the requirements for this control: AU-11 · Audit Record Retention Control Statement: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Supplemental Guidance: Retain audit records for [organization-defined parameter] to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements. Organizations retain

NIST SP 800-53 Rev 5 control AU-16 (Cross-organizational Audit Logging): AU-16 · Cross-organizational Audit Logging Control Statement: Employ [organization-defined parameter] for coordinating [organization-defined parameter] among external organizations when audit information is transmitted across organizational boundaries. Supplemental Guidance: Employ [organization-defined parameter] for coordinating [organization-defined parameter] among external organizations whe

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) requires organizations to implement the following: Control Statement: SR-03.03.06.a Implement an audit record reduction and report generation capability that supports audit record review, analysis, reporting requirements, and after-the-fact investigations of incidents. SR-03.03.06.b Preserve the original content and time ordering of audit records. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.06.

NIST SP 800-53 Rev 5 control AU-9.4 (Access by Subset of Privileged Users) is assessed by examining, interviewing, and testing: AU-9.4 · Access by Subset of Privileged Users Control Statement: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Supplemental Guidance: Authorize access to management of audit logging functionality to only [organization-defined parameter]. Individuals or roles with privileged access to a system and who are also the subject of an audit by that system may affect the reliability of the audit information by inhibiting audit activities or modi

(iii) Documents classified as RD or FRD must also include a Classification Authority Block with the RD derivative classifier's name and position, title, or unique identifier and the classification guide or source document (by title and date) used to classify the document. (iv) Other than the required subject or title markings, portion marking is permitted, but not required, for matter containing RD or FRD. Each agency that generates matter containing RD or FRD determines the policy for portion-marking matter generated within the agency. If matter containing RD or FRD is portion-marked, each portion containing RD or FRD must be marked with the level and category of the information in the portion (e.g., SRD, CFRD, S//RD, C//FRD). (v) Additional information and requirements are in 10 CFR 1045.140 . Requests for additional information about the classification and declassification of RD, FRD, and TFNI can be directed to Agency RD Management Officials or the DOE Office of Classification at outreach@hq.doe.gov or at (301) 903-7567. (7) Declassification. (i) No date or event for automatic declassification ever applies to RD, FRD, or TFNI documents, even if they contain classified NSI. RD, FRD, or TFNI documents remain classified until a positive action by a designated DOE official (for RD, FRD, or TFNI) or an appropriate DoD official (for FRD) is taken to declassify them. (ii) RD derivative classifiers may remove RD or FRD from portion-marked source matter if the resulting matter is not for public release. RD derivative classifiers cannot declassify matter marked as containing RD, FRD, and TFNI. Matter that potentially contains RD or TFNI must be sent to designated individuals in the DOE and those containing FRD must be sent to designated individuals in the DoD for declassification or removal of the RD, FRD, or TFNI prior to public release. (iii) Matter containing TFNI is excluded from the automatic declassification provisions of E.O. 13526 until the TFNI designation is properly removed by the DOE. When the DOE determines that a TFNI designation may be removed, any remaining classified information must be referred to the appropriate agency. (iv) Any matter marked as or that potentially contains RD, FRD, or TFNI within a document intended for public release that contains RD or FRD subject area indicators must be reviewed by the appropriate DOE organization. (8) Challenges to RD, FRD, and TFNI. A contractor employee who believes RD, FRD, or TFNI is classified improperly or unnecessarily may challenge that classification following the procedures established by the GCA. They may also send challenges directly to the Director, Office of Classification, AU-60/Germantown Building; U.S. Department of Energy; 1000 Independence Avenue SW, Washington, DC 20585, at any time. Under no circumstance is an employee subject to retribution for challenging the classification status of RD, FRD, or TFNI. (9) Commingling.

Under the FedRAMP Low baseline, AU-8 (AU-8 Time Stamps): FedRAMP Low Baseline · AU-8 · Time Stamps Control Statement: a. Use internal system clocks to generate time stamps for audit records; and b. Record time stamps for audit records that meet [organization-defined parameter] and that use Coordinated Universal Time, have a fixed local time offset from Coordinated Universal Time, or that include the local time offset as part of the time stamp. Supplemental Guidance: a. Use internal system clocks to generate time stamps for audit records; and b. Reco

NIST SP 800-53 Rev 5 control AU-6.9 (Correlation with Information from Nontechnical Sources) summarizes the requirements for this control: AU-6.9 · Correlation with Information from Nontechnical Sources Control Statement: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Supplemental Guidance: Correlate information from nontechnical sources with audit record information to enhance organization-wide situational awareness. Nontechnical sources include records that document organizational policy violations related to harassment incidents and the improper

NIST SP 800-53 Rev 5 control AU-16.3 (Disassociability) is assessed by examining, interviewing, and testing: AU-16.3 · Disassociability Control Statement: Implement [organization-defined parameter] to disassociate individuals from audit information transmitted across organizational boundaries. Supplemental Guidance: Implement [organization-defined parameter] to disassociate individuals from audit information transmitted across organizational boundaries. Preserving identities in audit

trails could have privacy ramifications, such as enabling the tracking and profiling of individuals, but may not be op

NIST SP 800-53 Rev 5 control AU-5 (Response to Audit Logging Process Failures) summarizes the requirements for this control: AU-5 · Response to Audit Logging Process Failures Control Statement: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-defined parameter]. Supplemental Guidance: a. Alert [organization-defined parameter] within [organization-defined parameter] in the event of an audit logging process failure; and b. Take the following additional actions: [organization-de

NIST SP 800-53 Rev 5 control AU-12 (Audit Record Generation) is defined as follows: AU-12 · Audit Record Generation Control Statement: a. Provide audit record generation capability for the event types the system is capable of auditing as defined in [AU-2a](#au-2_smt.a) on [organization-defined parameter]; b. Allow [organization-defined parameter] to select the event types that are to be logged by specific components of the system; and c. Generate audit records for the event types defined in [AU-2c](#au-2_smt.c) that include the audit record content defined in [AU-3](#au-3). Supplemental Guidance: a. Provide audit record generation capability for the event types the system i

NIST SP 800-171 Rev 3 control 03.03.08 (03.03.08 Protection of Audit Information) requires organizations to implement the following: Control Statement: SR-03.03.08.a Protect audit information and audit logging tools from unauthorized access, modification, and deletion. SR-03.03.08.b Authorize access to management of audit logging functionality to only a subset of privileged users or roles. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.08.

NIST SP 800-53 Rev 5 control AU-12.3 (Changes by Authorized Individuals) is assessed by examining, interviewing, and testing: AU-12.3 · Changes by Authorized Individuals Control Statement: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined parameter] within [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability for [organization-defined parameter] to change the logging to be performed on [organization-defined parameter] based on [organization-defined pa

Under the FedRAMP High baseline, AU-3.1 (AU-3.1 Additional Audit Information): FedRAMP High Baseline · AU-3.1 · Additional Audit Information Control Statement: Generate audit records containing the following additional information: [organization-defined parameter]. Supplemental Guidance: Generate audit records containing the following additional information: [organization-defined parameter]. The ability to add information generated in audit records is dependent on system functionality to configure the audit record content. Organizations may consider additional informatio

NIST SP 800-53 Rev 5 control AU-10 (Non-repudiation) is defined as follows: AU-10 · Non-repudiation Control Statement: Provide irrefutable evidence that an individual (or process acting on behalf of an individual) has performed [organization-defined parameter]. Supplemental Guidance: Provide irrefutable evidence that an individual (or process acting on behalf of an individual) has performed [organization-defined parameter]. Types of individual actions covered by non-repudiation include creating information, sending and receiving messages, and approving information. Non-repudiation protects against claims by authors of not having authored certain documents, senders o

NIST SP 800-171 Rev 3 control 03.03.02 (03.03.02 Audit Record Content) is assessed by examining the following: Assessment Objectives: - audit records contain information that establishes what type of event occurred. - audit records contain information that establishes when the event occurred. - audit records contain information that establishes where the event occurred. - audit records contain information that establishes the source of the event. - audit records contain information that establishes the outcome of the event. - audit records contain information that establishes the identity of the individuals, subjects, objects, or entities associated with the event. - additional information for audit re

NIST SP 800-53 Rev 5 control AU-12.2 (Standardized Formats) is assessed by examining, interviewing, and testing: AU-12.2 · Standardized Formats Control Statement: Produce a system-wide (logical or physical) audit trail composed of audit records in a standardized format. Supplemental Guidance: Produce a system-wide (logical or physical) audit trail composed of audit records in a standardized format. Audit records that follow common standards promote interoperability and information exchange between devices and systems. Promoting interoperability and information exchange facilitates the production of event

NIST SP 800-53 Rev 5 control AU-4 (Audit Log Storage Capacity) summarizes the requirements for this control: AU-4 · Audit Log Storage Capacity Control Statement: Allocate audit log storage capacity to accommodate [organization-defined parameter]. Supplemental Guidance: Allocate audit log storage capacity to accommodate [organization-defined parameter]. Organizations consider the types of audit logging to be performed and the audit log processing requirements when allocating audit log storage capacity. Allocating sufficient audit log storage capacity reduces the likelihood of such capacity being excee

Under the FedRAMP Moderate baseline, AU-7.1 (AU-7.1 Automatic Processing): FedRAMP Moderate Baseline · AU-7.1 · Automatic Processing Control Statement: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Supplemental Guidance: Provide and implement the capability to process, sort, and search audit records for events of interest based on the following content: [organization-defined parameter]. Events of interest can be identified by the content of audit

Under the FedRAMP High baseline, AU-9.2 (AU-9.2 Store on Separate Physical Systems or Components): FedRAMP High Baseline · AU-9.2 · Store on Separate Physical Systems or Components Control Statement: Store audit records [organization-defined parameter] in a repository that is part of a physically different system or system component than the system or component being audited. Supplemental Guidance: Store audit records [organization-defined parameter] in a repository that is part of a physically different system or system component than the system or component being audited. Storing audit re

Under the FedRAMP High baseline, AU-9 (AU-9 Protection of Audit Information): FedRAMP High Baseline · AU-9 · Protection of Audit Information Control Statement: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter] upon detection of unauthorized access, modification, or deletion of audit information. Supplemental Guidance: a. Protect audit information and audit logging tools from unauthorized access, modification, and deletion; and b. Alert [organization-defined parameter]

NIST SP 800-171 Rev 3 control 03.03.06 (03.03.06 Audit Record Reduction and Report Generation) is assessed by examining the following: Assessment Objectives: - an audit record reduction and report generation capability that supports audit record review is implemented. - an audit record reduction and report generation capability that supports audit record analysis is implemented. - an audit record reduction and report generation capability that supports audit record reporting requirements is implemented. - an audit record reduction and report generation capability that supports after-the-fact investigations of incidents is implemented. - the original content of audit records is preserved. - the original time ordering of audit

NIST SP 800-171 Rev 3 control 03.03.04 (03.03.04 Response to Audit Logging Process Failures) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Audit and Accountability (AU) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.03.05 (03.03.05 Audit Record Review, Analysis, and Reporting) is assessed by examining the following: Assessment Objectives: - system audit records are reviewed and analyzed [organization-defined parameter] for indications and the potential impact of inappropriate or unusual activity. - findings are reported to organizational personnel or roles. - audit records across different repositories are analyzed to gain organization-wide situational awareness. - audit records across different repositories are correlated to gain organization-wide situational

awareness.

NIST SP 800-53 Rev 5 control AU-13.1 (Use of Automated Tools) is defined as follows: AU-13.1 · Use of Automated Tools Control Statement: Monitor open-source information and information sites using [organization-defined parameter]. Supplemental Guidance: Monitor open-source information and information sites using [organization-defined parameter]. Automated mechanisms include commercial services that provide notifications and alerts to organizations and automated scripts to monitor new posts on websites.

NIST SP 800-53 Rev 5 control AU-6 (Audit Record Review, Analysis, and Reporting) summarizes the requirements for this control: AU-6 · Audit Record Review, Analysis, and Reporting Control Statement: a. Review and analyze system audit records [organization-defined parameter] for indications of [organization-defined parameter] and the potential impact of the inappropriate or unusual activity; b. Report findings to [organization-defined parameter] ; and c. Adjust the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence info

NIST SP 800-171 Rev 3 control 03.03.03 (03.03.03 Audit Record Generation) requires organizations to implement the following: Control Statement: SR-03.03.03.a Generate audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02. SR-03.03.03.b Retain audit records for a time period consistent with the records retention policy. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.03.

NIST SP 800-171 Rev 3 control 03.03.01 (03.03.01 Event Logging) requires organizations to implement the following: Control Statement: SR-03.03.01.a Specify the following event types selected for logging within the system: [organization-defined parameter]. SR-03.03.01.b Review and update the event types selected for logging [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.03.01.

AU-3.3 · Limit Personally Identifiable Information Elements Control Statement: Limit personally identifiable information contained in audit records to the following elements identified in the privacy risk assessment: [organization-defined parameter]. Supplemental Guidance: Limit personally identifiable information contained in audit records to the following elements identified in the privacy risk assessment: [organization-defined parameter]. Limiting personally identifiable information in audit records when such information is not needed for operational purposes helps reduce the level of privacy risk created by a system.

NIST SP 800-53 Rev 5 control AU-9.6 (Read-only Access) is defined as follows: AU-9.6 · Read-only Access Control Statement: Authorize read-only access to audit information to [organization-defined parameter]. Supplemental Guidance: Authorize read-only access to audit information to [organization-defined parameter]. Restricting privileged user or role authorizations to read-only helps to limit the potential damage to organizations that could be initiated by such users or roles, such as deleting audit records to cover up malicious activity.

NIST SP 800-53 Rev 5 control AU-9.6 (Read-only Access) is assessed by examining, interviewing, and testing: AU-9.6 · Read-only Access Control Statement: Authorize read-only access to audit information to [organization-defined parameter]. Supplemental Guidance: Authorize read-only access to audit information to [organization-defined parameter]. Restricting privileged user or role authorizations to read-only helps to limit the potential damage to organizations that could be initiated by such users or roles, such as deleting audit records to cover up malicious activity.

AU-10.2 · Validate Binding of Information Producer Identity Control Statement: (a) Validate the binding of the information producer identity to the information at [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Supplemental Guidance: (a) Validate the binding of the information producer identity to the information at [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Validating the binding of the information producer identity to the information prevents the modification of information between production and review. The validation of bindings

can be achieved by, for example, using cryptographic checksums. Organizations determine if validations are in response to user requests or generated automatically.

AU-10.4 · Validate Binding of Information Reviewer Identity Control Statement: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to release or transfer between [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Supplemental Guidance: (a) Validate the binding of the information reviewer identity to the information at the transfer or release points prior to release or transfer between [organization-defined parameter] ; and (b) Perform [organization-defined parameter] in the event of a validation error. Validating the binding of the information reviewer identity to the information at transfer or release points prevents the unauthorized modification of information between review and the transfer or release. The validation of bindings can be achieved by using cryptographic checksums. Organizations determine if validations are in response to user requests or generated automatically.

Under the FedRAMP High baseline, AU-1 (AU-1 Policy and Procedures): FedRAMP High Baseline · AU-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] audit and accountability policy that: 2. Procedures to facilitate the implementation of the audit and accountability policy and the associated audit and accountability controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the audit and account